Man-In-The-Middle (MITM) and Reply Attacks

Dr. Pinaki Sankar Chatterjee

What is a Man-In-The-Middle (MITM) Attack?

An MITM attack refers to a broad range of active eavesdropping techniques in which an attacker attempts to intercept, read, or alter information moving between two or more computers.

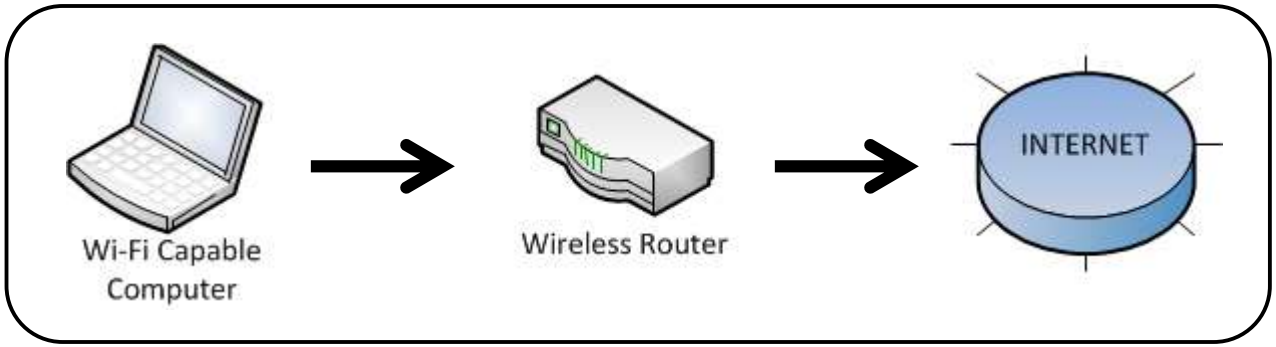
These attacks allow a 3rd party to interject themselves between separate systems and act as an electronic go-between, anonymously observing data while passing information back and forth between the other systems.

This form of information gathering/altering is also sometimes referred to as a Bucket Brigade or Janus attack.

How MITM Attacks Work

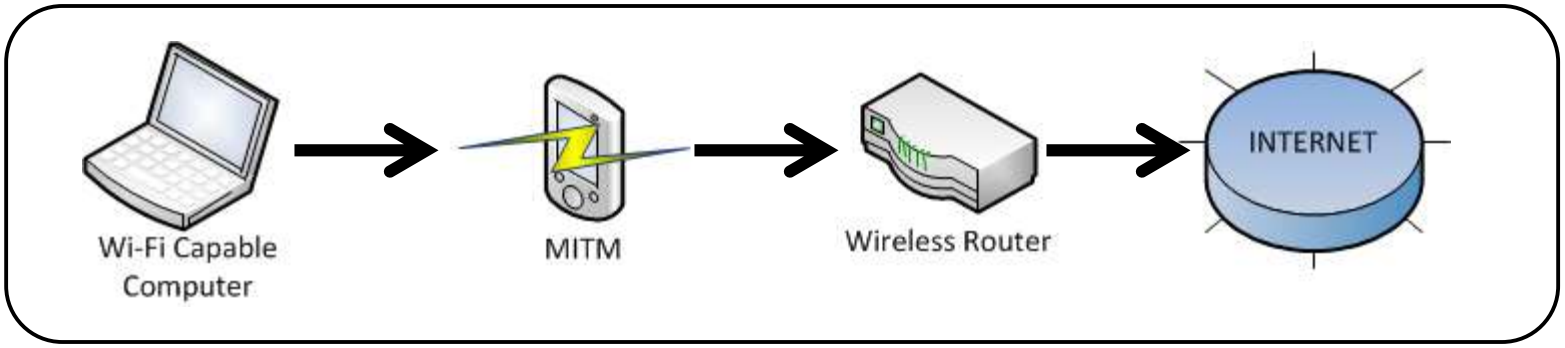
There are several methods for employing an MITM attack. However, they all rely on the ability to fool a system into believing that it is communicating securely.

During normal operations a Wi-Fi capable computer authenticates with a wireless router which allows it to connect to a network, intranet or internet.



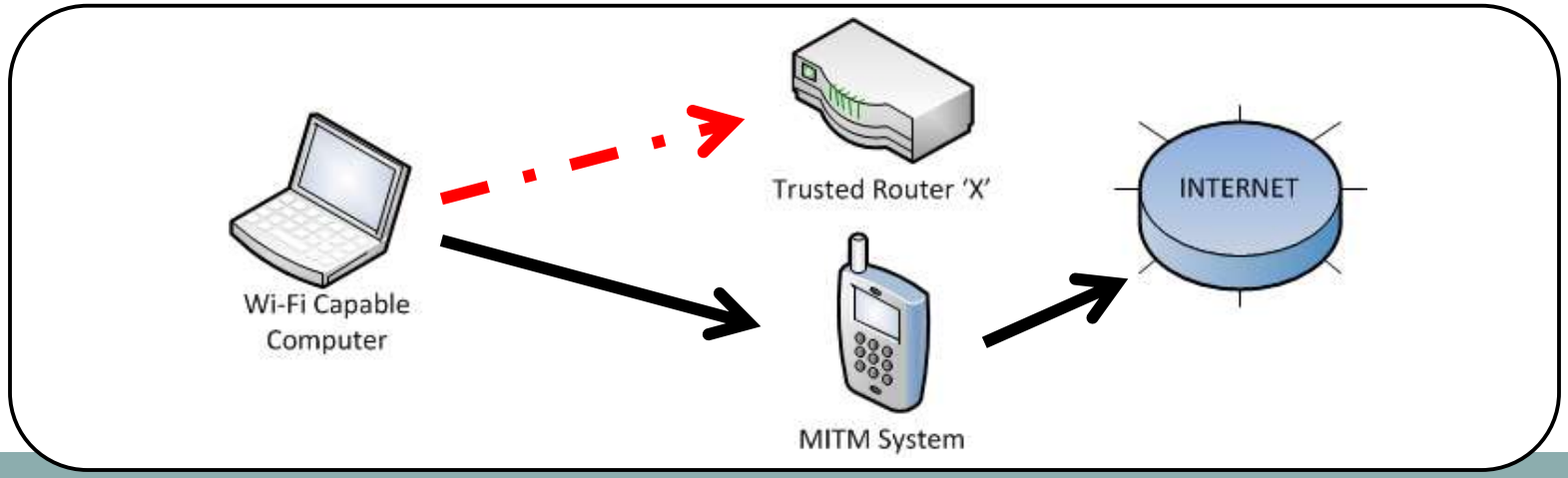
How MITM Attacks Work

During an MITM attack the 3rd party steps in between the targeted computer and a router when the computer first attempts to initiate a connection. The MITM then intercepts communications between the computers. In this position the MITM acts as a proxy; reading, altering, and inserting data in the communications stream. This allows the MITM to capture transmitted files, public keys, cookies, and passwords passed between the systems.



How MITM Attacks Work

Some systems may actively imitate a trusted network by setting up a Wi-Fi connection with a generic name or creating a separate ad hoc system. It is also possible for hardware to imitate the response from a trusted router and then route all data through its own connection to the internet. This form of MITM is sometimes referred to as a 'honeypot'.



How MITM Attacks Work

MITM attacks can occur if –

1. An attacker is in control of a router along the normal point of traffic communications.

2. An attacker is located on the same broadcast domain as the target.

3. An attacker is located on the same broadcast domain as any of the routing devices used by the target.

Areas of high risk include any location in which your computer system utilizes Wi-Fi signals for access, such as airports, hotels, restaurants, and even homes.

Vulnerabilities Created by MITM Attacks

MITM attacks have the potential to compromise communications and risk the inadvertent disclosure of sensitive information.

A significant issue with this form of attack is that any loss of information may be completely undetectable as the data is read while transferring between systems.

Resources to conduct MITM attacks are progressively more reliable and easier to employ, leading to a larger potential user base.

There is an increased number of public venues which provide free Wi-Fi. It is relatively simple for personnel in these areas to employ MITM attacks, especially in areas where the Wi-Fi router lacks password protection.

Countermeasures to Prevent MITM Attacks

⇒Use hardwired, or non Wi-Fi, connections whenever possible. Utilize ethernet cables or direct tethering to avoid potential Wi-Fi vulnerabilities. During hotel stays, use the ethernet cables available in most rooms instead of Wi-Fi.

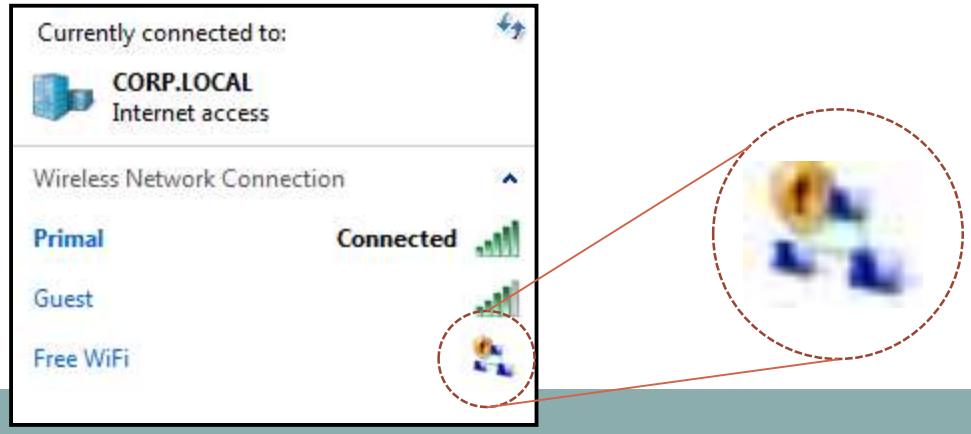
⇒Don't connect to public Wi-Fi systems. If you do connect, limit the type of information which you transmit. Avoid logging on to any websites or accounts which require a password. If you do use a password, change it when you are once again on a hardwired connection.

⇒Utilize Virtual Private Network (VPN) connections or sites which operate through Hypertext Transfer Protocol Secure (HTTPS) to increase security. Please remember that VPN and HTTPS may not be sufficient to secure your information.

Countermeasures to Prevent MITM Attacks

⇒Turn off "Auto Connect" for your wireless devices. This will require you to enter your password each time you attempt to connect to known Wi-Fi systems.

⇒Examine the source of the Wi-Fi signals before attempting to connect. Ad Hoc networks typically show up differently and could represent a 3rd party attempting to hijack your connection.



This symbol represents an 'ad hoc' connection. Do not connect to this wireless source.

Introduction to Replay Attacks

A replay attack is a form of network attack.

The attacker intercepts and resends valid data transmissions.

Goal: Gain unauthorized access or trick a system.

How Replay Attacks Work

Step 1: Attacker captures data (e.g., login credentials, tokens).

Step 2: Waits or alters context.

Step 3: Re-sends the data to impersonate the user or repeat the transaction.

Real-World Example

Example:

User logs in to a system using a token.

Attacker captures the token via unsecured Wi-Fi.

Attacker replays the token to gain access.

Impact of Replay Attacks

- Unauthorized access
- Financial fraud
- Data leakage
- System manipulation

Vulnerable Systems

Legacy authentication systems

IoT devices

Contactless payment systems

Poorly encrypted communications

Prevention Techniques

- Use nonces (numbers used once)
- Timestamps to verify message freshness
- Session tokens with short expiration
- Encryption with integrity checks
- Implement challenge-response authentication

Protocols with Replay Protection

- HTTPS (with TLS)
- Kerberos
- OAuth 2.0 (with expiration & scopes)
- Mutual TLS (mTLS)

- Replay attacks are simple but dangerous.
- Can be prevented with proper cryptographic techniques and protocols.
- Always secure communication channels.

Difference

Man-in-the-Middle (MITM) Attack and Replay Attack are both types of cyberattacks, but they differ in how they work and what they aim to do.

An attacker secretly intercepts and possibly alters the communication between two parties who believe they are communicating directly with each other.

An attacker captures legitimate data transmissions (usually authentication tokens or credentials) and re-sends them later to trick the system.